I.E.S. Ribera del Tajo

Técnico Superior en Administración de Sistemas Informáticos en Red

Tarea PIMAS 02

Proyecto intermodular de Administración de Sistemas Informáticos en Red

Autor:
Gabriel Abellán Rodríguez

8 de marzo de 2026

Índice

1. Introducción **3**

2. Módulos implicados **4**

3. Estudio de Mercado **5**

4. Análisis DAFO **5**

5. Servicios que ofrezco **7**
5.1. Venta online de productos 7
5.2. Envíos y logística 7
5.3. Atención al cliente con Inteligencia artificial 7
5.4. Registrarse verificando email 7
5.5. Restricción de Recursos por Seguridad Web 8
5.6. Efectos y Notificaciones en pantalla 8

6. Base de Datos **9**
6.1. Esquema 9

7. Detalles técnicos de la Página Web **10**
7.1. Tecnologías que usé 10
7.2. Diseño Responsive y Archivos CSS 10

8. Copias de seguridad / Backups **11**

9. Conexiones externas y Otras Aplicaciones **12**

10. Gestión de Empresa y Plan de Negocio **12**
10.1. Modelo de Ingresos 12
10.2. Plan Jurídico Fiscal 12
10.3. Plan de Inversiones y Viabilidad 13
10.4. Ubicación Inicial y Escalabilidad del Negocio 13

11. Protección de Datos (LOPD) **14**

12. Prevención de Riesgos Laborales (PRL) **15**

13. Infraestructura y Red Interna **16**
13.1. Esquema y Segmentación de Red con IP 16

14. Sistemas Operativos y Configuraciones Especiales **17**
14.1. Uso fundamental de Windows Server 17

15. Migración a Entornos Linux y Virtualización (Docker) **19**
15.1. Estructura de Contenedores 19
15.2. Beneficios escalables en el despliegue 20

16. Monitorización y Supervisión del Sistema **20**
16.1. Parámetros Múltiples y Métricas Sensibles 20

17. Ciberseguridad Continua y Hardening del Host **21**
17.1. El Aseguramiento Técnico sobre el Acceso de Terminal Remoto (SSH) 21
17.2. Transmisión Web Blindada y Cifrado mediante Certificados Libres (HTTPS TSL/SSL) 22
17.3. Reglas Exclusivas de Permisividad Externa: Cortafuegos de Host Local (UFW) 23

18. Anexo: Galería de la Página Web **24**
18.1. Navegación e Inicio de la Tienda 24
18.2. Proceso de Compra 25
18.3. Verificación y Acceso 26
18.4. Herramientas de Inteligencia Artificial 28
18.5. Atención al Cliente 31
18.6. Vista Móvil (Diseño Responsive) 32

1. Introducción

El objetivo de este proyecto es el desarrollo de una página web funcional y atractiva orientada a la venta e información de juegos de cartas coleccionables, comúnmente conocidos como JCC. Este tipo de juegos ha experimentado un gran crecimiento en los últimos años, tanto en número de jugadores como en la compra de los productos asociados. Con esta propuesta se pretende hacer una web que no solo sirva para comprar cartas y accesorios relacionados, sino también como un punto de aprendizaje para jugadores de todos los niveles.

La web estará dividida en distintas secciones bien diferenciadas: una tienda donde se podrán comprar productos relacionados con los JCC (cartas sueltas, sobres, accesorios, etc.), un apartado de guías introductorias para cada uno de los juegos principales del mercado, y un espacio informativo que explique el funcionamiento general. De esta forma, se busca reunir en una sola página lo que ahora está fragmentado en varias webs, es decir, unificar todo lo necesario en un solo lugar.

El diseño de la página está enfocado en ser intuitivo, bastante visual y responsive, para que pueda ser utilizado cómodamente desde cualquier dispositivo, ya sea ordenador, tablet o un teléfono móvil. El contenido se ofrecerá en varios idiomas, al menos en español e inglés, para llegar a un público más amplio.

El desarrollo del proyecto me ha permitido poner en práctica los conocimientos que he aprendido durante los dos cursos del ciclo formativo de ASIR, como, por ejemplo, montar la página web con programación básica en JavaScript y PHP, montar la base de datos, configurar la red del servidor y mejorar el diseño visual con CSS puro.

2. Módulos implicados

- Administración de Sistemas Operativos: He usado los conocimientos de este módulo para instalar y configurar el sistema operativo del servidor. Además, he creado algunos scripts en Bash para intentar automatizar pequeñas copias de seguridad de la base de datos para no perder los datos.

- Planificación y Administración de Redes: Para la gestión y configuración de la red básica si alojo el proyecto en un servidor propio.

- Fundamentos del Hardware: Me ha sido útil para entender el montaje y mantenimiento de los equipos que voy a usar a lo largo del desarrollo.

- Inglés: He utilizado el inglés para añadir una funcionalidad a la página de traducción, para que pueda utilizarse tanto en Español como en Inglés.

- Lenguaje de Marcas: He usado HTML5 y CSS3 para crear la web visualmente. He intentado usar CSS separado en distintos archivos para organizarme mejor, e implementado funciones interactivas y notificaciones visuales llamativas programadas en JavaScript básico.

- Implantación de Aplicaciones Web: Me ha servido para alojar la web con servidor Apache y enlazar PHP con el sistema.

- Itinerario Personal para la Empleabilidad: Para redactar el plan de prevención de riesgos laborales del documento.

- Gestión y Administración de base de datos: Para hacer en MySQL la base de datos de usuarios y productos del proyecto, utilizando algunas cosas algo más complejas vistas en clase como los Triggers.

- Seguridad y Alta Disponibilidad: Para configurar algún aspecto básico de seguridad como el SSH de los accesos.

3. Estudio de Mercado

Público objetivo: Principalmente me dirijo a gente entre 15 y 35 años a los que les guste mucho el coleccionismo o jugar a cosas de Pokémon. Me voy a centrar primero en ventas para España por el tema logístico, pensando en ampliar más adelante a Europa.

Competencia: En este sector hay mucha gente comprando y vendiendo. Tengo que intentar que la web se vea más amigable que las de la competencia. Entre los principales rivales hay:

- Pokémon Center España: Tienen precios más altos y a veces no tienen stock, pero es la oficial.
- Cardmarket: Es una página gigante tipo portal donde todos pueden comprar y vender. Suele haber gastos de envíos altos o timos porque cualquiera vende.
- Tiendas locales: Hay tiendas con ventas en físico, pero en ciudades como Talavera los precios suelen ser también elevados.

Por eso, debo ofrecer algo que llame mucho la atención visualmente en la web y además ser rápido enviando los productos.

Demanda: Pokémon sigue siendo una franquicia enorme hoy en día. Mucha gente compra las cartas y no paran de subir en demanda, aunque haya momentos donde las compras bajen o se estabilicen según la época del año.

Estrategia de marketing: Quiero apoyarme en usar redes sociales, como Instagram, creando algún short en YouTube que dirija la atención a mi tienda. También intentaré que el nombre PokePimas funcione bien en los buscadores utilizando el SEO.

4. Análisis DAFO

Debilidades:

- Como negocio web, tengo que ser yo quien actualice todo el rato los envíos, el stock y comprobar si algo llega o no y evitar que los usuarios tarden en recibir un correo.
- Al ser una tienda online totalmente nueva, no me conocerá mucha gente al principio, compitiendo contra gigantes de internet.
- Tengo dependencia de las novedades de esta franquicia para seguir vendiendo.

- El dinero para comprar cartas a los proveedores y distribuidores para ganar bastante margen es alto al comienzo.

Amenazas:

- Si a un proveedor se le acaban las novedades, yo me quedaré sin poder vender también.
- Riesgos de que me cuelen falsificaciones; aunque los filtre, a veces están muy bien hechas.
- Costes de envíos con plataformas como Correos que a veces suben de precio sin avisar, reduciéndome el beneficio final.

Fortalezas:

- Producto que encanta a todos: A las personas nostálgicas y coleccionistas les encantan las cartas, por lo que casi se venden solas si están en buen estado.
- Hacer la web desde Talavera significa ahorrar dinero si en un futuro tengo que pagar el alquiler de un almacen pequeño en comparación a ciudades como Madrid.
- Como he creado el sistema con notificaciones animadas, un bot inteligente, SMTP, etc., la gente sentirá que es una página premium, moderna, y seria.

Oportunidades:

- El mercado de cartas Pokémon no para de crecer en España y en todo internet.
- Hay bastante hueco para interactuar en redes con la gente haciendo vídeos que te redirijan a mi web nueva.
- Podré añadir productos secundarios o complementos en el futuro cuando gane dinero, como por ejemplo álbumes o fundas.

5. Servicios que ofrezco

La página web busca hacer muy sencilla la compra para aquellos que son un poco novatos o para la gente habitual que sólo busca algo rápido.

5.1. Venta online de productos

El servicio principal es la venta online de cajas (productos sellados) y también de cartas concretas y sueltas de todo el catálogo. La web está separada en dos secciones limpias para eso.

5.2. Envíos y logística

La idea es usar empresas de mensajería para toda España, empaquetando yo mismo cada pedido cuidadosamente para que a las cartas no se le doblen las esquinas ni sufran ningun desperfecto.

5.3. Atención al cliente con Inteligencia artificial

He configurado e integrado funcionalidades para la atención de los usuarios:

- Página para resolver dudas comunes.
- Formulario de contacto hacia un correo oficial.
- PimasBot AI: He insertado un pequeño asistente con JavaScript que usa la conexión a la Inteligencia Artificial de Google Gemini. Hace de encargado de mi tienda y resuelve casi todas las dudas comunes y simples.
- PokeLens: También he programado una herramienta que permite al usuario subir la foto de su carta a la web y, usando la Inteligencia Artificial de imágenes de Google, detecta por sí solo de qué Pokémon o personaje se trata para facilitar que se lo encuentre en mi página sin tener que escribirlo a mano en ningún buscador, simplificando el esfuerzo del usuario.

5.4. Registrarse verificando email

Utilizando los temarios de servicios de red y base de datos he conseguido enlazar mi código PHP con el sistema SMTP (Sendmail). Con esto, cuando

la persona pone sus datos durante el registro, el servidor le envía un correo electrónico a su cuenta de Gmail con un código de varios dígitos para poder verificarle la cuenta y que puedan utilizar varias funcionalidades de la web.

5.5. Restricción de Recursos por Seguridad Web

Es vital destacar que no cualquier visitante que entre de forma anónima podrá utilizar todos los servicios. Por motivos estrictos de rendimiento y seguridad, funcionalidades como el Carrito de la compra o las peticiones hacia el Chatbot IA estarán bloqueadas por servidor de forma que solo los usuarios registrados y logueados puedan utilizarlas.

De esta forma evitamos o mitigamos considerablemente la posibilidad de sufrir un ataque bot de denegación de volumen de peticiones o aquellos destinados a colapsar un equipo al mandar millones de instrucciones innecesarias iterativas contra el chat de Gemini. Esta validación obligatoria blinda los recursos web impidiendo que todo el servidor agote su CPU y su RAM (o nuestro cupo gratuito de IAs) y termine colapsando o tumbando el servicio de la tienda general por culpa de la saturación.

5.6. Efectos y Notificaciones en pantalla

Cuando el cliente va navegando en la web, los objetos y las tarjetas hacen un salto de sombras usando unas clases de animaciones CSS que he aprendido, para que parezca más profesional. Además, he cambiado las alertas del navegador y las sustituí por notificaciones modernas tipo 'toast' (una pequeña cajita elegante en la esquina superior derecha de la web avisándote cuando agregas algo).

6. Base de Datos

Para la base de datos me conecto mediante un código en el servidor con MySQL local usando XAMPP y phpMyAdmin durante el desarrollo, cuando se realice la implementación a un entorno real utilizaré un servidor alojado en docker. He intentado crear unas tablas donde guardo mis usuarios y luego saco los listados de la gente y productos.

6.1. Esquema

Este es la imagen en captura que muestra más o menos un diagrama Entidad/relación simple con lo básico de mi diseño.

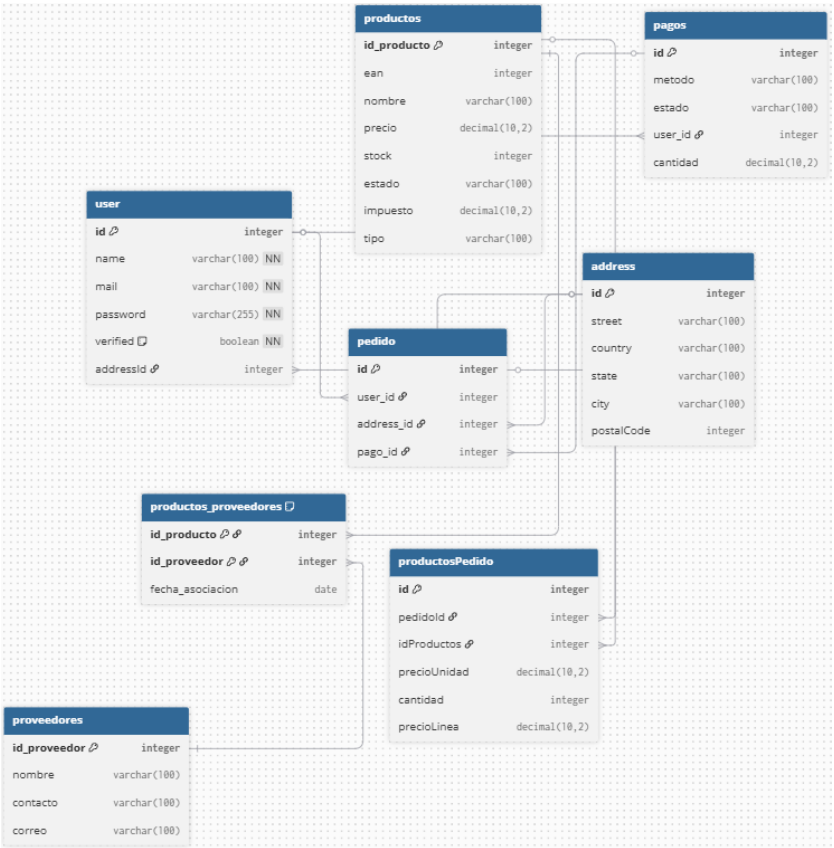


Figura 1: Diagrama Entidad-Relación de la base de datos.

7. Detalles técnicos de la Página Web

Siguiendo el modelo habitual, mi proyecto consta más o menos de 3 partes: el código web, la parte en el servidor PHP, y la base de datos SQL.

7.1. Tecnologías que usé

- Frontend (Diseño web): Lo he programado desde cero empleando HTML y CSS puro. He añadido una carpeta con JS básico para darle algo de funcionalidad y programar las notificaciones. De esta forma, logro que mi página no consuma apenas memoria del dispositivo a la persona que entra y cargue la web y los recursos.

- Backend (Servidor local): Utilicé código nativo de PHP usando $_SESSION para asegurar cuándo está un usuario registrado. Programé un sistema de conexión utilizando el servicio SMTP para la verificación de correos, así como un firme sistema de seguridad en los inicios de sesión desarrollando un cifrado con BCRYPT y bloqueo temporal por cuenta en caso de ataques de fuerza bruta.

- Base de Datos (SQL): El almacén de los productos y los usuarios. He insertado funciones especiales llamadas (Triggers) que vigilan la base de datos y ordenando automáticamente ciertas acciones por debajo para tener más facilidad y control.

- IAs Google (APIs): Conecté también mi código de JavaScript (usando el método fetch) usando mis propias keys hacia los servidores de Gemini AI para dar funcionalidad a los complementos PimasBot y al analizador de fotos PokeLens en mi web.

7.2. Diseño Responsive y Archivos CSS

Toda la página la empecé estructurando de tal manera que en lugar de un archivo css gigante que no haya quien entienda, lo dividí en varios archivos más limpios como uno solo para el menú, otro solo para botones, etc. La barra además cambia desde portátil al formato tablet, activando un menú colapsable como tienen casi todas las APPs modernas hoy en día.

8. Copias de seguridad / Backups

Uno de los principales temas en los sistemas es mantener a salvo mi base de datos de usuarios si cometo un error y elimino una columna, o si a la máquina local le entra un virus.

He utilizado algunos trucos técnicos como Triggers desde la base de datos que ejecutan en segundo plano ciertos pequeños comandos en Bash en el sistema operativo nativamente. También he creado scripts guardados en carpetas internas que puedo lanzarlos como administrador cuando considere o usando las tareas del sistema cron para guardar una copia mysqldump comprimida que podré rescatar después o sacarla hacia fuera de mi ordenador y restaurarla.

9. Conexiones externas y Otras Aplicaciones

Por otro lado, quería tener de forma apartada una App o algo que yo mismo instale en mi teléfono para tener una manera de listar el inventario local.

Para poder administrar algunas existencias lo más sencillo ha sido tratar de conectar en un futuro ciertos apartados de mi servidor LAMP con unas apis desarrolladas en herramientas de baja codificación como Appian, un software lowcode que he aprendido en las prácticas. Así, cuando haya una venta, el servidor web envía una sencilla modificación mediante un código JSON para interactuar directamente y restarme en un inventariado físico los paquetes vendidos en un formato más simple de leer que todo mi panel de PHP o de SQL.

10. Gestión de Empresa y Plan de Negocio

10.1. Modelo de Ingresos

Los ingresos de mi marca, llamada PokePimas, vienen de tres apartados principales para poder mantener el servicio y lograr rentabilidad económica:

1. Comprar a distribuidores oficiales y vender producto sellado: Se trata de productos nuevos comprados en lote directo al proveedor (por ejemplo, cajas de sobres o .ETBs"). Al venderlas a su precio de venta recomendado obtengo un margen de beneficio seguro.

2. Vender cartas sueltas valiosas: Este será el pilar del negocio en internet. Comprar cartas especiales y revenderlas debidamente tasadas a los que las necesitan para sus competiciones. Aquí, la ganancia final suele llegar a ser del 50 % dependiendo del estado del cartón.

3. Venta de Complementos: Al final todo jugador acabará añadiendo al carrito de compra productos necesarios como fundas protectoras o archivadores, aumentando el total del gasto medio con un margen enorme.

10.2. Plan Jurídico Fiscal

A nivel logístico empresarial, como es un proyecto individual y partimos desde cero, la figura más factible y lógica para arrancar la actividad es darme de alta como Trabajador Autónomo. Si tratara de crear una Sociedad Limitada (S.L.) de primeras me vería obligado a aportar un capital de 3.000€

y tendría muchísimos más trámites y recargos con las gestorías. Actuando como autónomo podré empezar a funcionar de forma totalmente legal para emitir mis facturas cobrando el IVA adecuado, además de permitirme poder deducir en mis declaraciones gastos lógicos como la cuota del host donde alojo la página o el equipo informático que necesito para mantener todo abierto.

10.3. Plan de Inversiones y Viabilidad

Para poner mi tienda a funcionar y preparar toda la estructura orientada de momento, he pensado detallar una tabla con los costes estimados o iniciales que necesito para abrir y desarrollar esto:

Concepto de Inversión Inicial	Coste Estimado
Hardware (Servidor local genérico, Switch Cisco y Router)	1.300 €
Licencias (Windows Server u otros sistemas)	600 €
Dominio Web y el Host/VPS en la nube (Gasto de un año)	80 €
Stock primero de arranque (Sobres y artículos Pokémon)	2.500 €
Material preparado para enviar paquetes (Sobres burbuja)	150 €
Total Inversión Inicial Estimada para PokePimas	4.630 €

Tabla 1: Previsión básica de inversiones - PokePimas.

La idea general a nivel viabilidad es tener esto como dinero amortizado mediante mis ahorros y recuperar dicha inversión a lo largo de un año y medio. No hace falta que contrate a un asesor informático externo, ya que como estudiante del ciclo yo mismo gestiono sin coste la web y red del negocio.

10.4. Ubicación Inicial y Escalabilidad del Negocio

Al tratarse de un proyecto de emprendimiento individual y nacido desde cero (Bootstrapping), la ubicación inicial tanto del equipo servidor como del inventario y almacén de las cartas será mi propio domicilio particular. Esto me confiere una ventaja inicial inmensa al eliminar de raíz los gastos fijos mensuales correspondientes al alquiler de un local comercial y suministros de luz o agua extras asociados a establecimientos empresariales. Todo mi cuarto o espacio designado se adaptará logísticamente de forma segura para conservar el cartón sin humedades y empacar envíos por mi cuenta.

Sin embargo, el proyecto PokePimas nace con una visión completamente orientada a la escalabilidad. Si las métricas de tráfico web crecen, y el volumen de envíos comienza a desbordar la capacidad operativa y de almacenamiento de una vivienda, el siguiente paso de viabilidad comercial ya está planificado:

1. El salto a un alquiler de almacén o pequeña oficina local desde la cual poder separar el ámbito personal del profesional.
2. La contratación de un empleado / mozo de almacén para realizar los empaquetados diarios.
3. La adquisición y montaje de gabinetes Rack propiamente dichos, escalando el sencillo servidor en torre inicial a infraestructuras de montaje en rack, mejorando enormemente los anchos de banda simétricos con operadoras locales y profesionalizando cada eslabón del proyecto.

11. Protección de Datos (LOPD)

A día de hoy es indispensable por ley el cumplir con el Reglamento General de Protección de Datos (RGPD), sobre todo en mi página, ya que un usuario tiene que darme contraseñas y direcciones personales para poder enviarle paquetes. Se cumple con ello del siguiente modo:

- El Registro Seguro: Para que puedan usar la página he puesto mecanismos para que al registrarse se deba confirmar la comprensión del tratamiento en la web, de forma que el usuario apruebe y sepa que sus direcciones postales están resguardadas en la empresa solo por cuestiones vitales de envío y compras.
- Base de Datos Intocable: Los parámetros de contraseña no viajan jamás legibles al registro de MySQL. Durante la recepción de los datos en mi PHP se encriptan de forma segura utilizando el algoritmo robusto BCRYPT a través de la función password_hash(). De esta forma, si por cualquier motivo atacaran mi base de datos, el asaltante sólo robaría un código hash asimétrico e indescifrable, por lo que quedan a salvo.
- Protección contra Fuerza Bruta en Autenticaciones: Para fortalecer la ciberseguridad, he implementado un sistema en la base de datos de control de intentos. Si una persona introduce la contraseña de forma incorrecta 3 veces en la pantalla de inicio de sesión, el sistema actualizará la base de datos y bloqueará el acceso de la cuenta afectada automáticamente durante 15 minutos de seguridad obligatorios.
- Mi Política de Cookies: La web avisa o utilizará aquellas cookies estrictamente técnicas. Esto significa que usaré los datos de navegación alojando un id en el navegador únicamente para que la página sea capaz de recordar"que tu sesión está abierta o si tienes objetos añadidos al carro de compra sin estar rastreando las aficiones de los clientes.

12. Prevención de Riesgos Laborales (PRL)

Ya que estaré mucho tiempo frente a la pantalla programando o empaquetando yo mismo, debo tomar estos cuidados preventivos:

- Fatiga Visual al código: Emplear sillas lumbares homologadas para no hacerme daño, hacer paradas usando la vista de lejos, y emplear un monitor con iluminación indirecta sin brillos altos durante mi trabajo.
- Riesgos en el Almacén de cartas: Al manejar bastantes cajas con mucho material, tenderé a empacarlos cogiendo bien las cajas con la espalda totalmente vertical para que las lumbares no cedan.
- Riesgos Eléctricos en el ordenador servidor: Tendré cuidado y aseguraré no usar anillos al abrir los servidores, utilizando un enchufe o elemento a tierra físico antes de hacer mantenimientos del servidor o los discos para no quemar los equipos limpiando y por propia prevención anti-chispazos.

13. Infraestructura y Red Interna

En ASIR, el diseño de la red local física es el centro vital de cualquier despliegue. Por eso mi proyecto cuenta con configuraciones dedicadas para poder hospedar todos mis servicios (como la web y los equipos del almacén local) protegiéndolos fuertemente de intrusiones de internet.

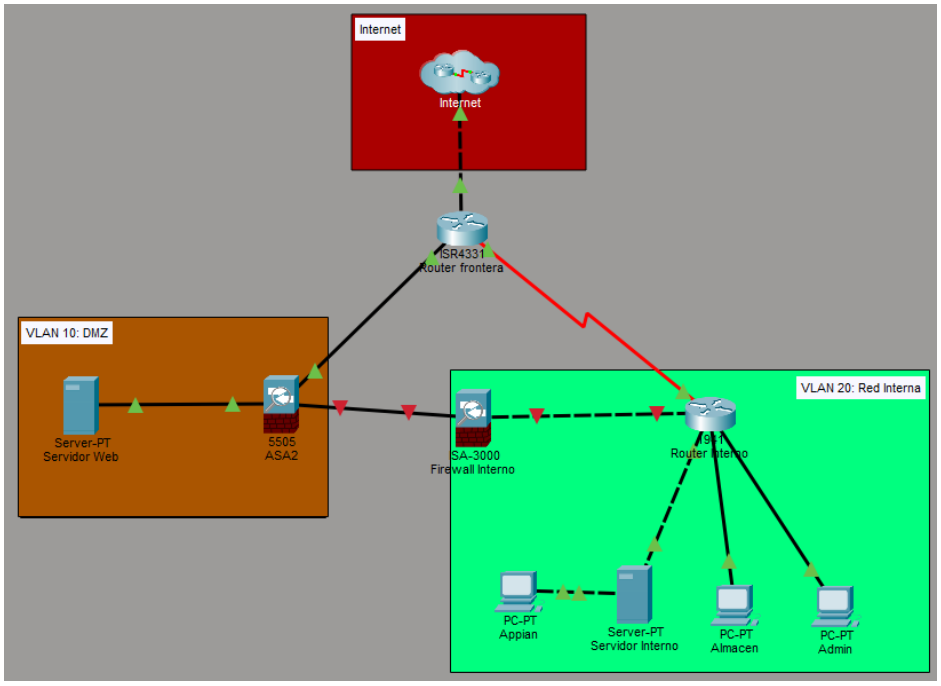


Figura 2: Esquema lógico de la red interna.

13.1. Esquema y Segmentación de Red con IP

Toda la oficina emplearía inicialmente un direccionamiento 192.168.1.0/24 administrado por un Switch gestionable. Sin embargo, no puedo mezclar de golpe todo el tráfico para que internet llegue a las bases de datos. Para proteger todo mi modelo, la red local usaría virtualizaciones para partir el equipo y el cableado (VLANs locales):

- VLAN 10 o DMZ (Servidor expuesto): Aquí es donde ubico el ordenador que hace del alojamiento Web final. Todo router frontera (ya sea con pfsense o de empresa) obligatoriamente cortará cualquier tráfico y solo redirigirá mediante los puertos abiertos de entrada “80” y “443” las peticiones hacia la IP de mi servidor, dejando al propio Apache de cara y blindado contra la internet exterior.

- VLAN 20 (Para SQL y los equipos físicos de mi almacén): Una subred desconectada total y herméticamente para gente que entre por internet. Nadie accede a mi disco duro con bases de datos ni a un equipo de empleado. Solo la aplicación web que programé y ubiqué en la VLAN 10 tiene permiso, tras abrir cortafuegos estáticos, para enrutar sus comprobaciones cruzadas hacia esta zona para rescatar un valor.

14. Sistemas Operativos y Configuraciones Especiales

Para gestionar este entorno a un nivel propio y adecuado a estos estudios no basta con limitarse a encender el Apache en equipos caseros XAMPP. El objetivo claro y final es migrar todo el ecosistema de máquinas físicas, orquestando todas las rutinas web del servidor de desarrollo con capacidades muy profesionales en ramas Microsoft.

14.1. Uso fundamental de Windows Server

Es la base principal e ideal sobre la cual puedo levantar la infraestructura de este negocio. Se utilizará previsiblemente Windows Server 2022 porque simplificando las interfaces me dará herramientas completísimas que hemos dado en el aprendizaje práctico. Esta tecnología incluye los siguientes servicios justificados de enorme potencial:

- Configuración del Active Directory (AD): Esto me servirá radicalmente para tener estructuradas y jerarquizadas todas mis cuentas y los ordenadores. Un operario mozo de almacén no podrá tocar la base de datos de los precios, porque he generado roles bloqueados por cuentas de usuarios diferentes, permitiendo tocar el núcleo del host solo a la cuenta de usuario "sysadmin".

- Levantar el DNS Interno en Windows: Haciéndolo yo en la red gano bastante para mi código. Pongo una IP directa local a mi zona de resolución e instalo un "DNS"para que los equipos entiendan mi red. Así me ahorro problemas graves de red pudiendo pedir un dato a bases.pokepimas.local en vez de referirme al equipo escribiendo directamente IPs y fallando cuando existan los traspasos DHCP lógicos en mis oficinas.

- Usar directrices (GPOs) del Server contra Infecciones: De las decisiones operativas más importantes para bloquear desastres corporativos. Des-

de esta consola del dominio aplico unas reglas de "GPO"por la red al equipo del almacén que bloqueen físicamente los lectores de "pendrives/ ÜSB", denegando su lectura y erradicando un gran porcentaje del riesgo de entrada del secuestrador o virus de la empresa común hacia mis discos críticos de bases de datos.

15. Migración a Entornos Linux y Virtualización (Docker)

A pesar de que el entorno de Directorio Activo se soporta en Windows Server para gestión de usuarios físicos y equipos locales, la rama de producción donde correrá la web se desplegará sobre una distribución GNU/Linux (Ubuntu Server 24.04 LTS), ya que siempre ofrece una estabilidad absoluta y consumo de recursos mínimo (al carecer de pesadas interfaces gráficas) siendo esta la arquitectura ideal para hospedar tecnologías en internet.

15.1. Estructura de Contenedores

La arquitectura de la tienda PokePimas se encapsulará totalmente utilizando la tecnología de Docker. A través de un archivo de orquestación llamado docker-compose.yml, aislaré los servicios web de la máquina física en unos micro-entornos bajo un mismo host. Esta segregación en servicios conlleva un enorme control de los recursos:

- Contenedor Web (Frontend/Backend): En forma de imagen oficial basada en php:8.2-apache. Éste único entorno será el que se encargará en exclusiva de servir la página web estática a los navegadores y de compilar el código dinámico de PHP. Únicamente este contenedor tendrá permiso para exponer sus túneles de enlace hacia la red de oficina y a internet.

- Contenedor SQL (Base de Datos): Partimos de una imagen en limpio y muy rápida basada en MySQL 8.0 o MariaDB. Este contenedor estará protegido y hermético gracias a las redes internas virtuales (docker_network) que provee el propio motor de Docker. En la práctica real, este subsistema de motor carece de cualquier puente o comunicación hacia el exterior, logrando mayor ciberseguridad para nuestras tablas vitales.

- Mapeo de Volúmenes (Volumes): Toda la información almacenada en las bases de datos transcurre virtualizada, pero no puede borrarse al apagar el contenedor. Así, todos los clústeres de base de datos críticos montarán sistemas lógicos contra el disco duro anfitrión (empleando comandos de mapeo Volumes), por lo que se obtiene la tan deseada persistencia de sesión. Si el contenedor se bloquea, se reinicia o se corrompe por una mala actualización, no existirá pérdida de producto o información alguna de los clientes tras levantarse nuevamente.

15.2. Beneficios escalables en el despliegue

Docker proporciona una escalabilidad altísima para el sistema empresarial. Al tratarse de ecosistemas preconfigurados y empaquetados como ïmágenes", en un futuro cercano y sin tocar casi los servidores raíz del disco, se podrían orquestar y controlar los servicios efímeros mediante Kubernetes con reglas .ªutoscaling", multiplicando y clonando el Apache y PHP de manera inmediata y automática solo en caso de que un pico inusual de tráfico sature el servicio (como las épocas de Navidad o de lanzamientos valiosos de cartas).

16. Monitorización y Supervisión del Sistema

Un departamento informático y en concreto un técnico ASIR no solamente configura los servicios del ecosistema productivos esperando a que funcionen; lo crítico y más costoso es tener implementada una monitorización ininterrumpida que prevenga el desastre 24 horas al día.

Por esto la plataforma implementará y estará observada por métricas activas provenientes del centro de la infraestructura usando y desplegando servicios de Zabbix.

16.1. Parámetros Múltiples y Métricas Sensibles

A fines de lograr que el sistema albergue la mayor tasa de disponibilidad exigida en el proyecto, el servidor central contendrá de manera forzada y encubierta la herramienta "Zabbix Agent"; con la responsabilidad de remitir cada pequeño intervalo de algunos segundos un volcado exacto enviando a la controladora maestra estos datos trascendentales:

- Sobrecargas severas de CPU/RAM: Es primordial monitorizar los picos imprevistos o los incrementos progresivos inusuales del propio uso de la RAM o procesadores, los cuales pueden darnos pistas cruciales relativas a que la tienda puede estar sufriendo lo llamado ataques de saturación volumétrica o ataques DDoS. Permitirá intervenir el sistema en medio de la congestión y repeler ataques de red y cuellos de botella para que no impacte a los clientes de las cajas base.

- Avisos Cuota del Almacenaje Base Backup: Es muy típico y fatal en el sector IT un almacenamiento bloqueado de manera sorpresiva y silenciosa. Como he dispuesto la lógica de que extrae y comprime volcados periódicos por bash o cron jobs, de modo paulatino corremos riesgo. El medidor enviará lecturas a Zabbix alertando de inminente cierre

temporal un mensaje en naranja al rebasar el bloque del 85 % en los repositorios web. Antes de un fallo mortal tipo 100 % que colapsaría y dejaría "Broken Down"los servidores SQL e impactaría los ficheros log.

- Disponibilidad del Üptimez Ping Check: Por pura fiabilidad visual he montado "validaciones directas automáticas"(Zabbix Web Scenarios). Periódicamente se hacen llamadas web reales desde otro emplazamiento sin interfaz; validando la respuesta completa y esperable y sin fallo y una carga del carrito. Si en el sondeo programático de Zabbix existiese una respuesta diferente y alterada a los estados esperados HTTP 200 OK, automáticamente rebotará y gestionará el envío global del mensaje al propio correo electrónico directo asignado al control gerencial con carácter crítico inmediato alertando sobre un servicio fallido en vivo.

17. Ciberseguridad Continua y Hardening del Host

Previo requerimiento para asegurar el servicio que saldrá expuesto tras configurarlo todo en el entorno protegido a la internet pura global, será preciso y prudente aplicar protocolos rigurosos, restrictivos del tipo "denegación completa", implementando de esta manera las normativas exigidas de un blindaje para el anfitrión (lo que en el ámbito de seguridad llamamos de manera profesional "Sever Hardening"hacia los demonios principales internos del Linux Ubuntu o similar al igual que Apache).

17.1. El Aseguramiento Técnico sobre el Acceso de Terminal Remoto (SSH)

El servicio OpenSSH instalado de fábrica será examinado y reforzaremos toda la conexión reestructurando archivos principales tales y como el documento /etc/ssh/sshd_config donde aplicaré directrices agresivas sin cuartel:

1. Cierre Total Vía Root y Logins Clásicos de Texto: Se detendrá por sistema rotundo la capacidad para conexión vía contraseña estándar en plano, utilizando los comandos PasswordAuthentication no. De la misma forma, un ataque a los superusuarios Root desde ordenadores remotos fuera de la infraestructura local está estrictamente capado por los parámetros de bloqueo de inicio genérico PermitRootLogin no.

2. Implementación exclusiva con Claves Asimétricas Avanzadas (RSA/ED25519): Resultando la regla suprema tras este despliegue criptográfico que para

poder entrar en terminal los propios administradores habilitados requerirán siempre acceder desde máquinas controladas aportando claves duales de nivel industrial y de altisima encriptación de seguridad, donde toda técnica empleando bibliotecas brutas con librerías matemáticas y diccionarios con ataques automáticos o por suposición sean estadísticamente y en tiempos humanos del todo fútiles.

3. Fail2Ban Control (Firewall Dinámico): Entendemos que siempre existirá tráfico anómalo sobre la IP que poseemos si no cortamos el mal de raíz mediante software reactivo automático. Así entra a ayudar el programa Fail2Ban. Todo bot, red de propagación masiva o ciberdelincuencia que falle las iteraciones un número controlado sobre un mismo recurso o en un puerto "honeypotçamuflado del host quedará registrado sus IPs globalmente e insertado en la política local del IPtables/UFW sin acceso por tiempos indefinidos. Logramos con esto un bloque general paralelo fortaleciendo por fuera al reciente y poderoso mecanismo "limitador temporizado por bloqueos consecutivos de cuentas con registro seguro PHP en la página principal.ªntes desarrollado e inyectado.

17.2. Transmisión Web Blindada y Cifrado mediante Certificados Libres (HTTPS TSL/SSL)

Si ya hemos implementando con la programación sistemas como algoritmos formidables BCRYPT de manera intrínseca protegiendo todas las combinaciones generadas en las claves hacia base datos transcurrida por medio web, nuestro deber y exigencia como técnicos y operarios en una tienda comercial electrónica conlleva el apartar el sistema obsoleto abierto expuesto y muy endeble que conocemos todos los expertos como HTTP clásico por defecto de configuración web. Implementaré:

- Las firmas automatizadas mediante acuerdos con entidades libres solidarias internacionales de alta certificación llamadas Let's Encrypt. En su implantación recurriré e instalaré los robots gestores Certbot nativamente ubicados internamente y que reinyectarán validaciones web por DNS temporizando periódicamente su renovación antes de expirar SSL/TLS asegurando un reconocimiento a nivel verde válido en los distintos buscadores a la vez de Google y Chrome para el usuario y su web.

- Con las directrices bien formadas, todo tráfico se fuerza a establecer obligatoriamente la escucha y comunicación por la puerta segura, con-

cretamente en nuestro caso se asigna el entorno estándar en puerto número "443çomo exigencia técnica generalizada, y utilizando comandos en los túneles directos por redirecciones estrictas e inflexibles habilitadas para "VirtualHost"desde nuestro contenedor maestro o software Apache/Nginx y con las directivas HTTP redirigidas de la manera formal por el modo motor clásico Rewrite Engine"logrando de forma impecable enmascarar los paquetes enviados de información mitigando sin excepciones los robos a la escucha por los criminales informáticos expertos, ataque este que típicamente de conoce como secuestros técnicos "Man In The Middle (MITM)".

17.3. Reglas Exclusivas de Permisividad Externa: Cortafuegos de Host Local (UFW)

Dejando constancia antes explicada el enorme aislamiento blindado entre capas (Red de la Empresa Frontal LAN → Router o FW PfSense → Zona Desmilitarizada Protegida Virtual Limitada → Nuestro Sistema), nuestro servidor maestro también tiene integrado otro segundo muro para protección contra virus introducidos, operarios descuidados o intentos de lateralización y brecha. Al instalar UFW aplico desde su propia raíz restrictiva directrices por barrido que conocemos técnicamente en todo el sistema ASIR llamado cierre preventivo "Deny-All", cerrando el tráfico completamente en todos los 65.535 puertos lógicos bloqueados a cero en la capa inferior general.

Desde aquí, exclusivamente programaremos comandos y abriremos a mano diminutos agujeros estrictamente necesarios mediante (Allow Open): Abriendo un Puerto SSH Reasignado lejos del 22 e invisible para evitar logs basura de escaner bot automático en internet de los criminales y finalmente abrimos hacía los enlaces del proxy o directo la escucha web "80 web tradicional HTTP que derivará a 443"permitiendo la transferencia a todo navegador o motor de dispositivo celular de los clientes interesados en las valiosas cartas o productos TCG listados con las galerías web.

18. Anexo: Galería de la Página Web

A continuación se adjunta una recopilación de imágenes para mostrar el diseño y el funcionamiento visual y práctico de la página web terminada.

18.1. Navegación e Inicio de la Tienda

Figura 3: Página de inicio de la tienda web.

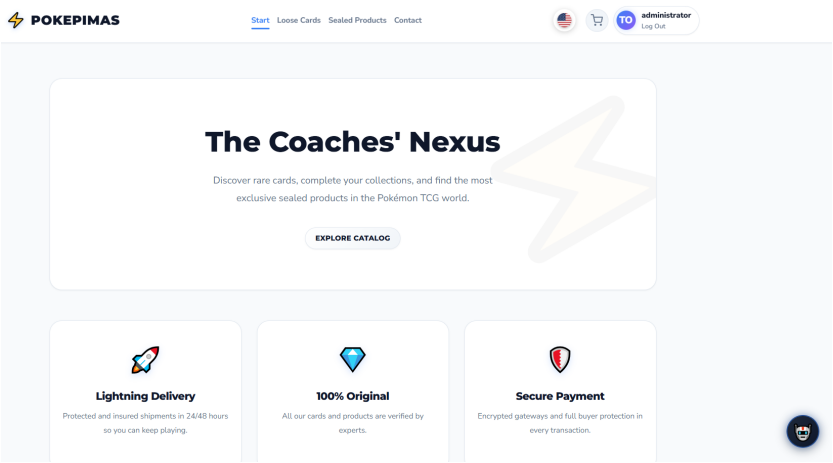


Figura 4: Página de inicio traducida al inglés mediante las banderas.

18.2. Proceso de Compra

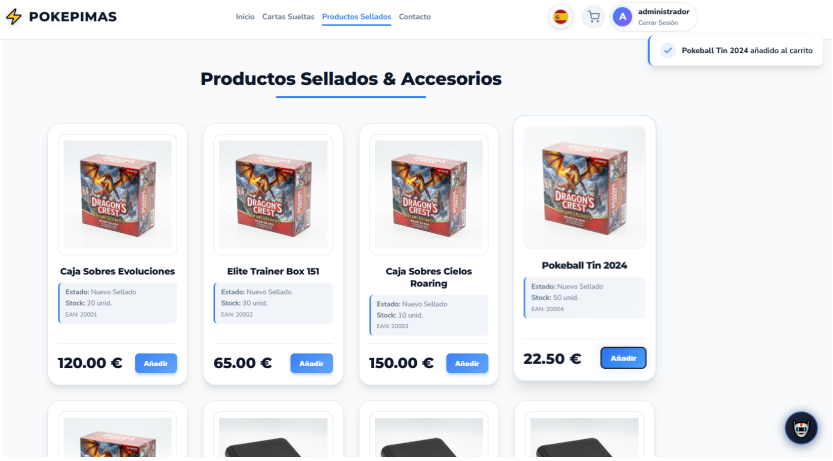


Figura 5: Vista de productos sellados al añadir un artículo al carrito.

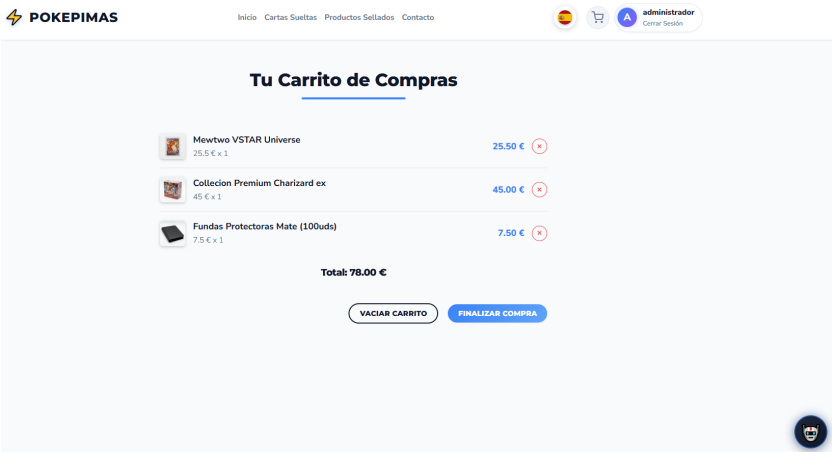


Figura 6: Carrito de compra con los productos añadidos.

18.3. Verificación y Acceso

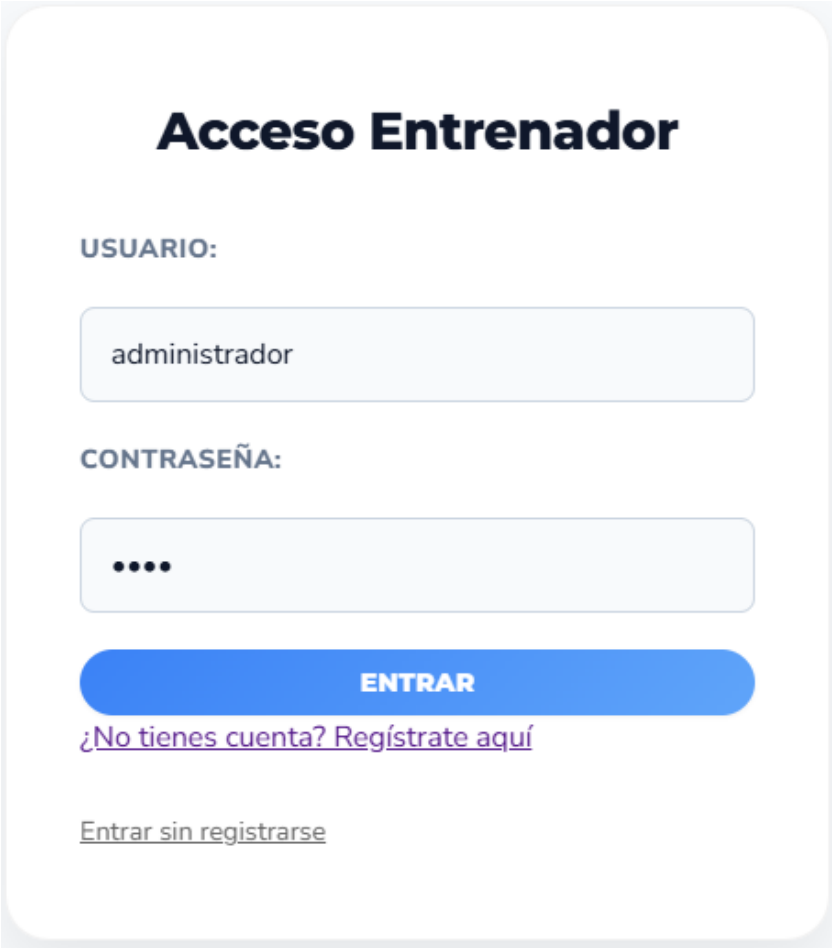
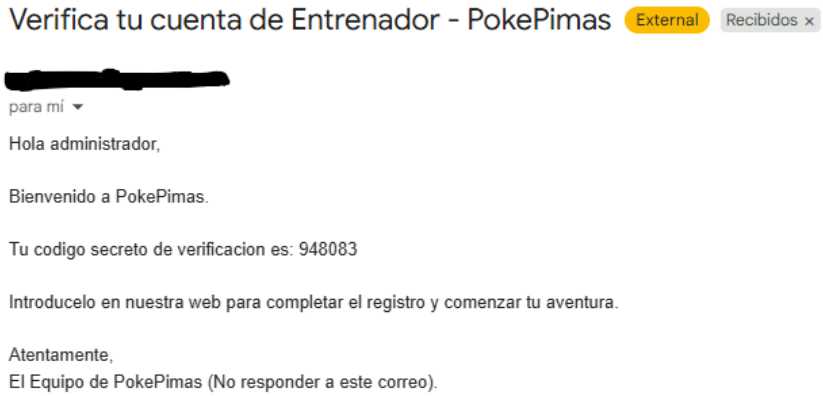


Figura 7: Página de login con un inicio de sesión básico basado en un formulario.



Verifica tu cuenta de Entrenador - PokePimas External Recibidos ×

[redacted]

para mí

Hola administrador,

Bienvenido a PokePimas.

Tu codigo secreto de verificacion es: 948083

Introducelo en nuestra web para completar el registro y comenzar tu aventura.

Atentamente,
El Equipo de PokePimas (No responder a este correo).

Figura 8: Correo con el código de verificación de la cuenta.

Figura 9: Página donde debemos meter el código que nos ha llegado para completar la verificación de la cuenta.

18.4. Herramientas de Inteligencia Artificial

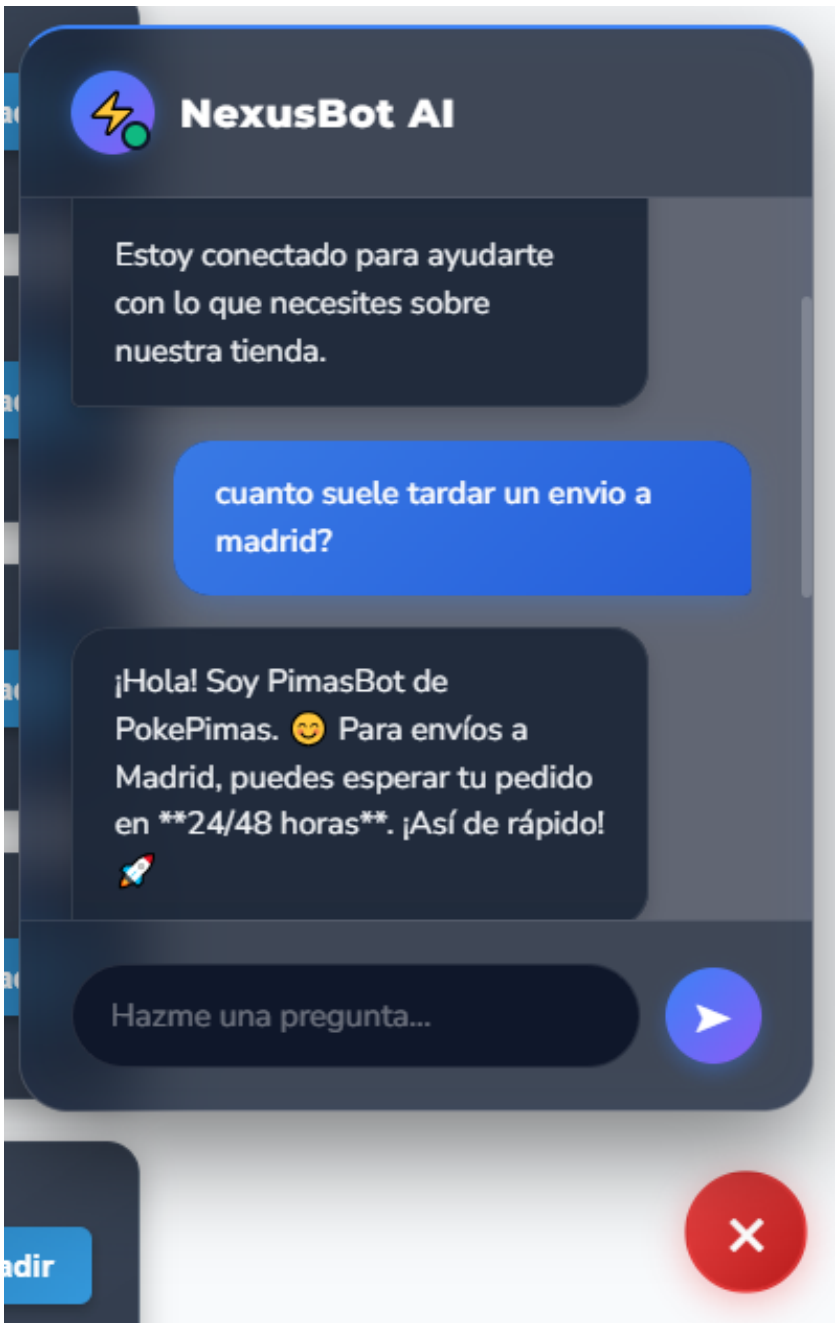


Figura 10: Ejemplo de conversación con el chatbot de la tienda.

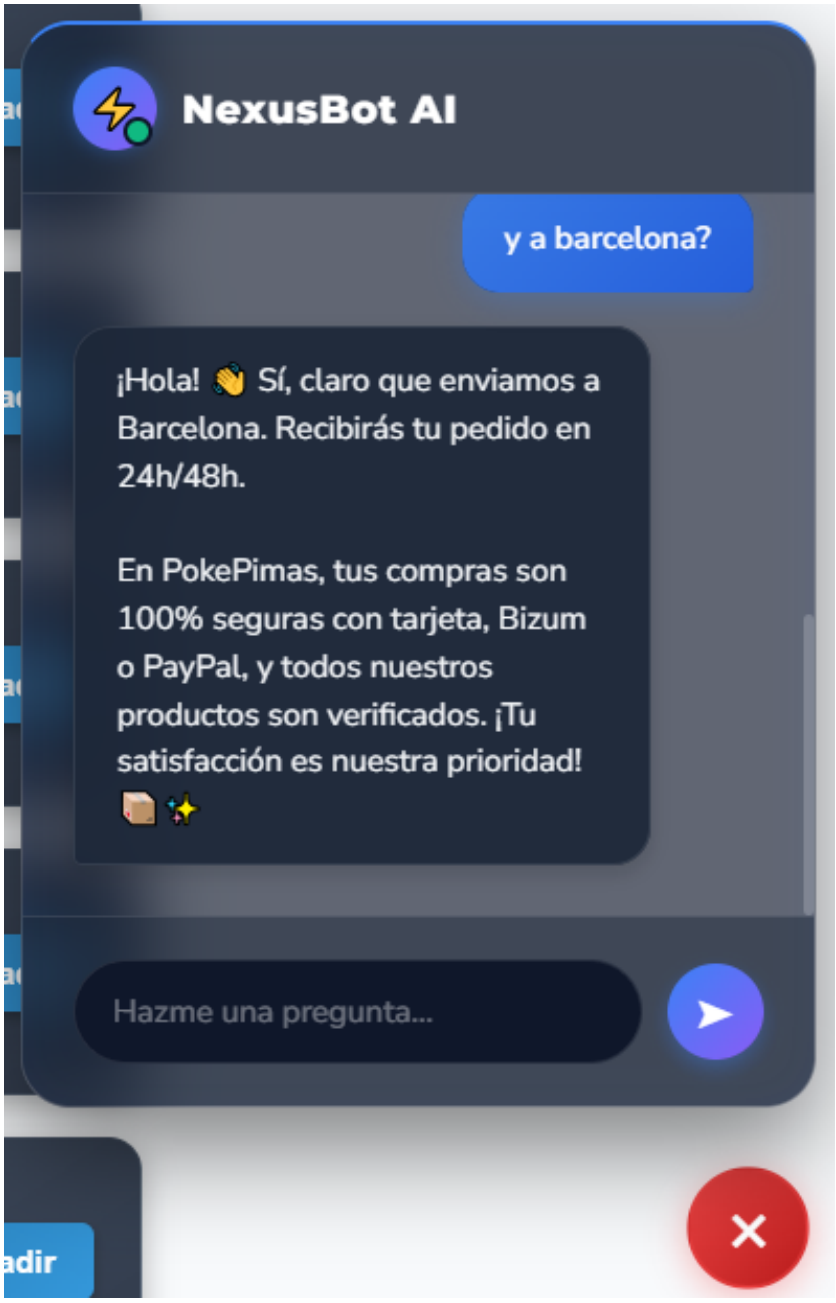


Figura 11: El chatbot resolviendo dudas.

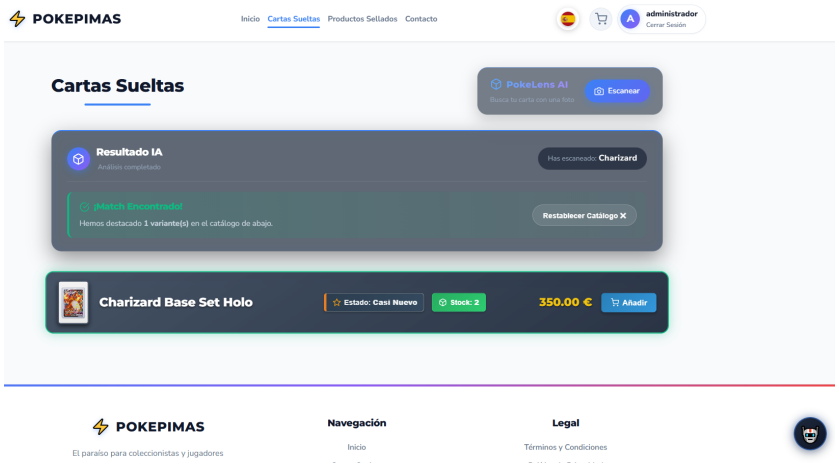


Figura 12: Herramienta PokeLens detectando una carta con éxito.

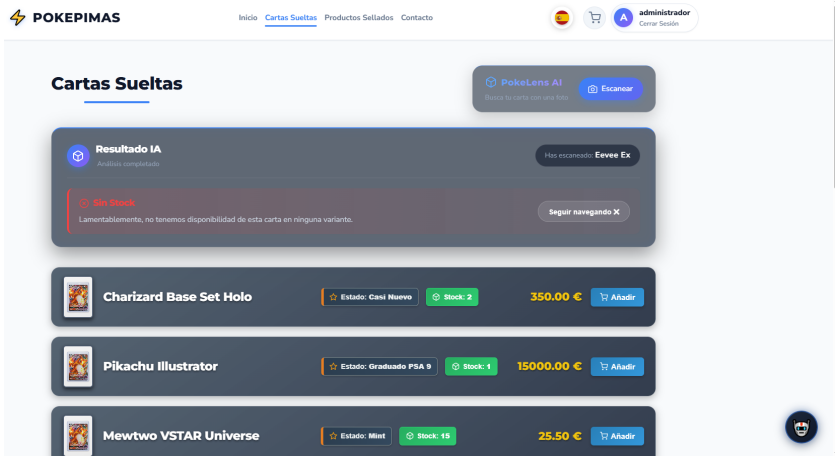


Figura 13: Herramienta PokeLens cuando no encuentra la carta en la base de datos.

18.5. Atención al Cliente

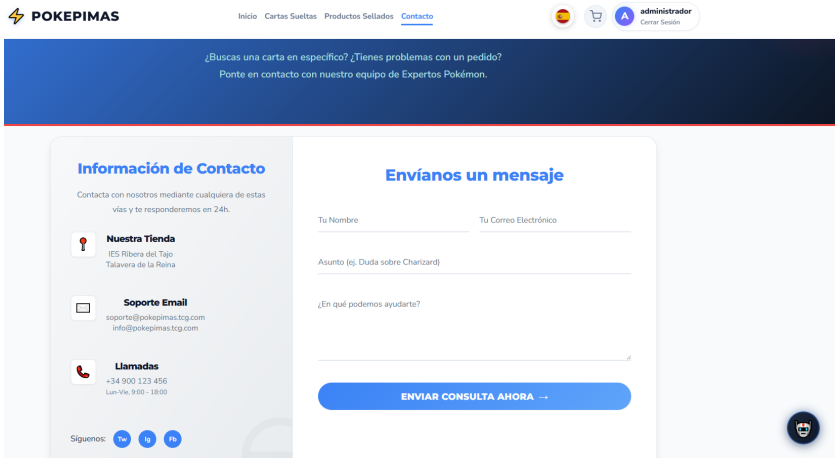


Figura 14: Página de contacto.

18.6. Vista Móvil (Diseño Responsive)

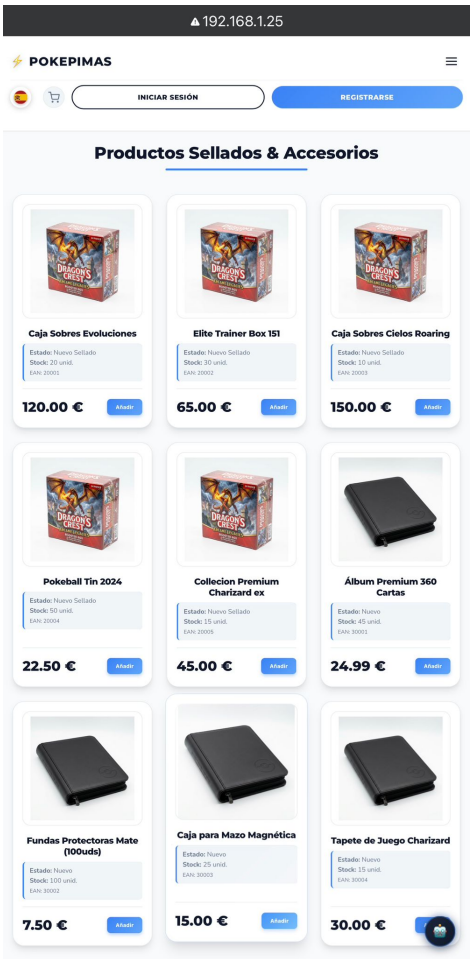


Figura 15: Visualización general de la interfaz adaptada a un teléfono móvil.

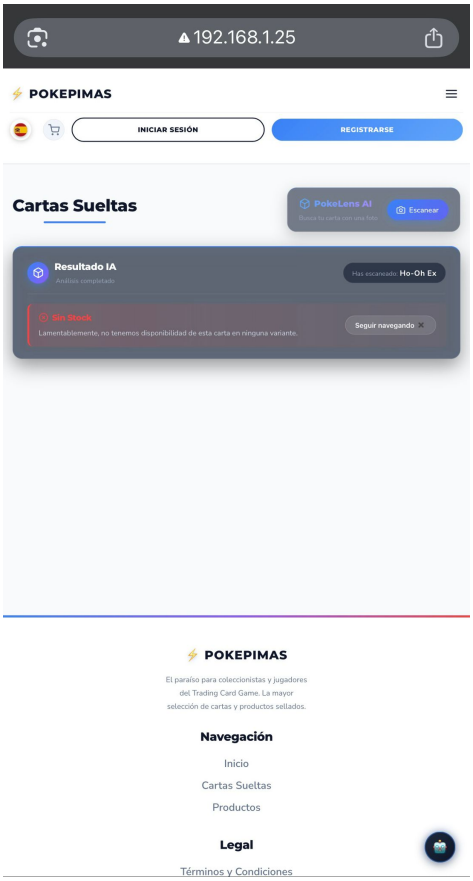


Figura 16: Menú de navegación principal desplegado en formato móvil.

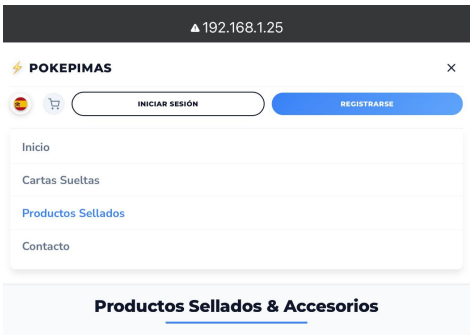


Figura 17: Vista del catálogo de productos y carrito adaptados a la pantalla táctil.